

Data leak worksheet

Incident summary: A sales manager shared access to a folder of internal-only documents with their team during a meeting. The folder contained files associated with a new product that has not been publicly announced. It also included customer analytics and promotional materials. After the meeting, the manager did not revoke access to the internal folder, but warned the team to wait for approval before sharing the promotional materials with others. During a video call with a business partner, a member of the sales team forgot the warning from their manager. The sales representative intended to share a link to the promotional materials so that the business partner could circulate the materials to their customers. However, the sales representative accidentally shared a link to the internal folder instead. Later, the business partner posted the link on their company's social media page assuming that it was the promotional materials.

Control	Least privilege
Issue(s)	<i>What factors contributed to the information leak?</i> <i>Not revoking access to the internal folder and business partner which led leaking private information online.</i>
Review	<i>What does NIST SP 800-53: AC-6 address?</i> <i>This addresses how an organisation needs to protect their data privacy, one way to achieve this is to use least privilege to prevent users from having elevated permissions that are outside of their role/responsibilities.</i>
Recommendation(s)	<i>How might the principle of least privilege be improved at the company?</i> <i>Only give access to data that is needed by the sales rep to complete their day to day tasks therefore restricting access to sensitive information. Also, audit user privileges to ensure the user has the right level of access to company data.</i>
Justification	<i>How might these improvements address the issues?</i> <i>If data is restricted to internal use only, it's less likely to be leaked and requires management to regularly audit user privileges to ensure users have the correct amount of access.</i>